

Nessus Scan

A new Nessus scan can be configured by clicking **New Scan**, and selecting a scan type. Scan templates fall into three categories: **Discovery**, **Vulnerabilities**, and **Compliance**.

Note: The scans shown in this section have already been pre-run to save you the time of waiting for them to finish. If you re-run the scan, it's best to go through vulnerabilities as they come, instead of waiting for the scan to finish, as they can take 1-2 hours to finish.

New Scan

Here we have options for a basic **Host Discovery** scan to identify live hosts/open ports or a variety of scan types such as the **Basic Network Scan**, **Advanced Scan**, **Malware Scan**, **Web Application Tests**, as well as scans targeted at specific CVEs and audit & compliance standards. A description of each scan type can be found [here](#).

Scan Templates

[Back to Scans](#)

Search Library

Scanner

DISCOVERY

**Host Discovery**
A simple scan to discover live hosts and open ports.

VULNERABILITIES

**Basic Network Scan**
A full system scan suitable for any host.

**Advanced Scan**
Configure a scan without using any recommendations.

**Advanced Dynamic Scan**
Configure a dynamic plugin scan without recommendations.

**Malware Scan**
Scan for malware on Windows and Unix systems.

**Mobile Device Scan**
Assess mobile devices via Microsoft Exchange or an MDM.

**Web Application Tests**
Scan for published and unknown web vulnerabilities.

**Credentialed Patch Audit**
Authenticate to hosts and enumerate missing updates.

**Badlock Detection**
Remote and local checks for CVE-2016-2118 and CVE-2016-0128.

**Bash Shellshock Detection**
Remote and local checks for CVE-2014-6271 and CVE-2014-7169.

**DROWN Detection**
Remote checks for CVE-2016-0800.

For the purposes of this exercise, we will choose the **Basic Network Scan** option, and we can enter our targets:

Settings

CredentialsPlugins

BASIC

GeneralScheduleNotifications

DISCOVERYASSESSMENTREPORTADVANCED

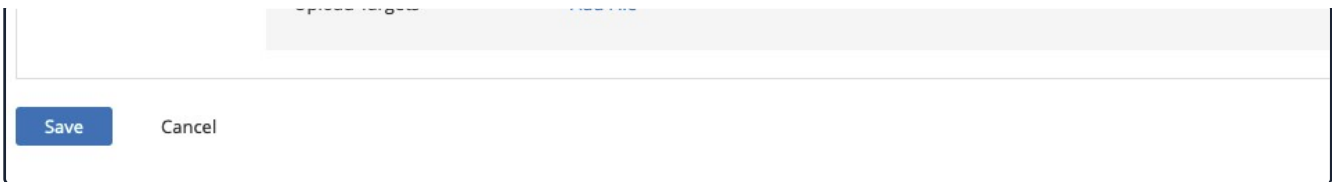
NameWindows_basic

Description

FolderMy Scans

Targets172.16.16.100

Upload TargetsAdd File

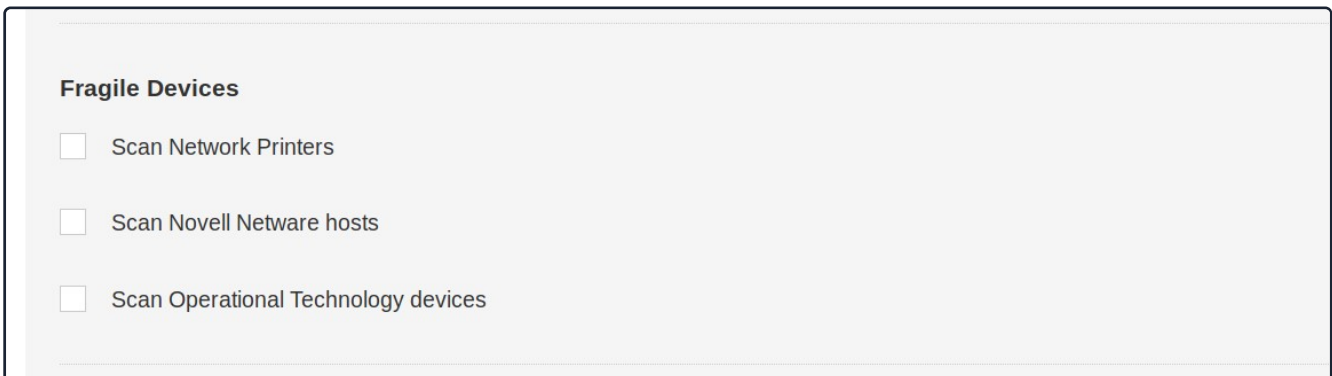


A dialog box with a light gray background. At the bottom, there are two buttons: a blue 'Save' button and a gray 'Cancel' button.

Note: For this module, the Windows target will be `172.16.16.100` and the Linux target will be `172.16.16.160`.

Discovery

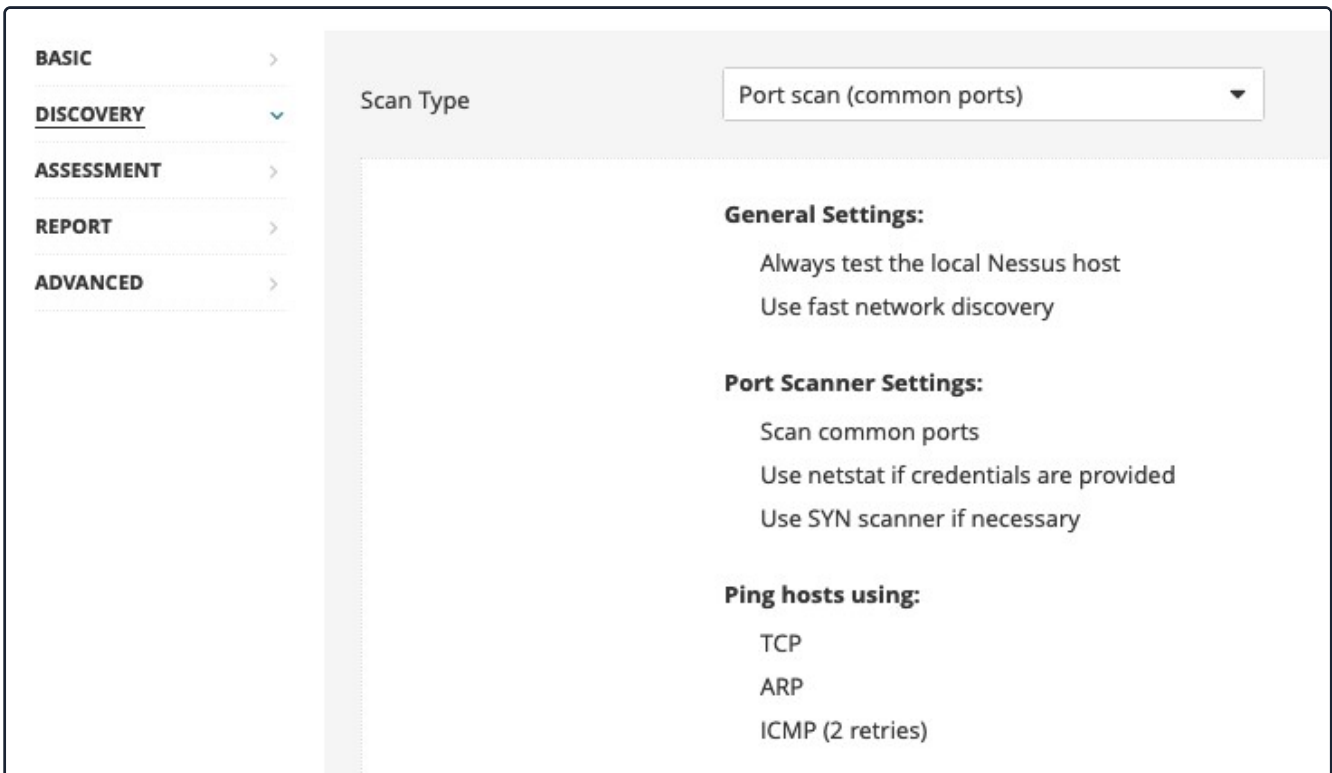
In the **Discovery** section, under **Host Discovery**, we're presented with the option to enable scanning for fragile devices. Scanning devices such as network printers often result in them printing out reams of paper with garbage text, leaving the devices unusable. We can leave this setting disabled:



A screenshot of the 'Fragile Devices' settings section. It has a light gray background and contains three unchecked checkboxes:

- ☐ Scan Network Printers
- ☐ Scan Novell Netware hosts
- ☐ Scan Operational Technology devices

In **Port Scanning**, we can choose whether to scan common ports, all ports, or a self-defined range, depending on our requirements:



A screenshot of the 'Port Scanning' configuration page. On the left is a sidebar with navigation links: **BASIC**, **DISCOVERY** (selected), **ASSESSMENT**, **REPORT**, and **ADVANCED**. The main content area has a 'Scan Type' dropdown menu set to 'Port scan (common ports)'. Below this are three sections of settings:

- General Settings:**
 - Always test the local Nessus host
 - Use fast network discovery
- Port Scanner Settings:**
 - Scan common ports
 - Use netstat if credentials are provided
 - Use SYN scanner if necessary
- Ping hosts using:**
 - TCP
 - ARP
 - ICMP (2 retries)

Within the **Service Discovery** subsection, the **Probe all ports to find services** option is selected by default. It's possible that a poorly designed application or service could crash as a result of this probing, but most applications should be robust enough to handle this. Searching for SSL/TLS services is also enabled by default on a custom scan, and Nessus can additionally be instructed to identify expiring and revoked certificates.

Assessment

Under the **Assessment** category, web application scanning can also be enabled if required, and a custom user agent and various other web application scanning options can be specified (e.g., a URL for Remote File Inclusion (RFI) testing):

Web Application Settings

Scan web applications ☒

General Settings

Use a custom User-Agent

Web Crawler

Start crawling from

Excluded pages (regex)

If desired, Nessus can attempt to authenticate against discovered applications and services using provided credentials (if running a credentialed scan), or else can perform a brute-force attack with the provided username and password lists:

General Settings

☐ Only use credentials provided by the user
Used to prevent account lockouts if your password policy is set to lock out accounts after several invalid attempts.

Oracle Database

☐ Test default accounts (slow)

Hydra

☐ Always enable Hydra (slow)
Nessus uses Hydra to attempt brute force attacks when either this setting or the "Perform thorough tests" setting in the "Assessment / General"

Logins file [Add File](#)

Passwords file [Add File](#)

User enumeration can also be performed using various techniques, such as RID Brute Forcing:

BASIC >
DISCOVERY >
ASSESSMENT ▾
General
Brute Force
Web Applications
• Windows
REPORT >
ADVANCED >

General Settings

☐ Request information about the SMB Domain

User Enumeration Methods

☒ SAM Registry
☒ ADSI Query
☒ WMI Query

RID Brute Forcing ☐

If we opt to perform RID Brute Forcing, we can set the starting and ending UIDs for both domain and local user accounts:

RID Brute Forcing

ON

Enumerate Domain Users

Start UID

1000

The beginning of a range of IDs where Nessus will attempt to enumerate domain users

End UID

1200

The end of a range of IDs where Nessus will attempt to enumerate domain users

Enumerate Local Users

Start UID

1000

The beginning of a range of IDs where Nessus will attempt to enumerate local users

End UID

1200

The end of a range of IDs where Nessus will attempt to enumerate local users

Advanced

On the **Advanced** tab, safe checks are enabled by default. This prevents Nessus from running checks that may negatively impact the target device or network. We can also choose to slow or throttle the scan if Nessus detects any network congestion, stop attempting to scan any hosts that become unresponsive, and even choose to have Nessus scan our target IP list in random order:

BASIC

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

General

General Settings

☒ Enable safe checks

☐ Stop scanning hosts that become unresponsive during the scan

☐ Scan IP addresses in a random order

Performance Options

☐ Slow down the scan when network congestion is detected

Network timeout (in seconds)

5

Max simultaneous checks per host

4

Max simultaneous hosts per scan

30

[< Previous](#)[Next >](#)[✔ Mark Complete & Next](#)

Table of Contents

Security Assessments

Security Assessments	✓
Vulnerability Assessment	✓
Assessment Standards	✓

Vulnerability Scoring and Reporting

Common Vulnerability Scoring System (CVSS)	✓
Common Vulnerabilities and Exposures (CVE)	✓

Nessus

Vulnerability Scanning Overview	✓
Getting Started with Nessus	✓

[Nessus Scan](#)

- Advanced Settings
- Working with Nessus Scan Output
- Scanning Issues
-  Nessus Skills Assessment

OpenVAS

- Getting Started with OpenVAS
- OpenVAS Scan
- Exporting The Results
-  OpenVAS Skills Assessment

Reporting

- Reporting

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left